EDENBRIDGE GRAMMAR
BEYOND SCHOOLING

Edenbridge Grammar School

Data Protection & Information Governance Policy

(Aligned with International Best Practice and Pakistan Regulatory Framework)

---

1. Purpose and Vision

Edenbridge Grammar School recognises that safeguarding personal data is fundamental to trust, institutional integrity, and responsible innovation. As a school integrating advanced digital learning platforms and AI-supported instruction, we are committed to protecting the privacy, dignity, and rights of all students, families, staff, and partners.

This policy establishes clear standards for:

- Lawful collection and processing of personal data
- Secure storage and responsible sharing of information
- Ethical use of digital and AI-supported systems
- Compliance with Pakistan's regulatory framework and recognised international standards

Data protection is not merely a compliance requirement; it is a core component of our safeguarding culture.

---

2. Legal and Regulatory Framework

Edenbridge Grammar School operates in accordance with:

Pakistan

- The Constitution of Pakistan (Right to Privacy)
- Prevention of Electronic Crimes Act (PECA) 2016
- Pakistan Personal Data Protection Bill (as applicable upon enactment)

- FIA Cyber Crime Wing guidance
- PTA digital data guidelines (where relevant)

International Good Practice Standards

- Principles aligned with UK GDPR and EU GDPR frameworks
- ISO/IEC 27001 information security principles
- UNICEF and UNESCO child data protection guidance
- International safeguarding standards for schools

Where international best practice exceeds local statutory minimums, Edenbridge will adopt the higher standard.

---

3. Scope

This policy applies to:

- All staff (teaching, administrative, leadership, contractors)
- Students and parents
- Governors and trustees
- Third-party service providers
- AI platforms, digital learning systems, and cloud services used by the school

It applies to both:

- Digital records
- Paper-based records

---

4. Key Principles

Edenbridge processes personal data according to the following principles:

1. **Lawfulness, Fairness, and Transparency**
   Data is processed legally and individuals are informed about how their data is used.

2. **Purpose Limitation**
   Data is collected only for specified, legitimate educational and operational purposes.

3. **Data Minimisation**
   Only necessary data is collected.

4. **Accuracy**
   Records are kept accurate and up to date.

5. **Storage Limitation**
   Data is retained only as long as required.

6. **Integrity and Confidentiality**
   Data is protected through robust technical and organisational measures.

7. **Accountability**
   The school demonstrates compliance through documentation and governance oversight.

8. **Deletion of Data**

   The school holds a clear set of standards on how Data will be deleted, once the time allotted is up or upon request by data holder.

5. Categories of Data Collected

Edenbridge may collect and process:

Student Data

- Identification information (name, date of birth, ID details)
- Academic records and assessments
- Attendance records
- Behaviour and Achievement records
- Learning profiles and AI-generated analytics
- Health and safeguarding information (where required)
- Photographs and media (with consent)

Staff Data

- Employment records
- Background checks
- Payroll and financial details.
- Performance reviews

Parent/Guardian Data

- Contact details
- Communication records.
- Financial records (fees and billing)

6. Lawful Bases for Processing

Data processing is carried out on the basis of:

- Educational necessity
- Legal obligations
- Safeguarding responsibilities
- Contractual necessity
- Explicit consent (where required)
- Legitimate interest (where appropriate and proportionate)

Sensitive data (e.g., health, safeguarding records) is processed with enhanced protections.

---

7. Data Security Measures

Edenbridge implements:

Technical Safeguards

- Encrypted cloud storage
- Secure password protocols
- Multi-factor authentication for sensitive system
- Role-based access control
- Secure AI integration protocols
- Firewall and anti-malware systems

7. Organisational Safeguards

Edenbridge Grammar School maintains structured organisational measures to ensure that personal data is handled responsibly, securely, and in accordance with regulatory obligations.

All staff members receive mandatory data protection training as part of their induction process. This includes understanding lawful data handling, confidentiality expectations, safeguarding-linked data responsibilities, and digital security awareness. Refresher training is delivered annually to reinforce compliance and respond to emerging risks.

All employees, contractors, and volunteers sign confidentiality agreements as part of their contractual obligations. These agreements clearly outline responsibilities regarding the handling, storage, sharing, and protection of personal information.

Access to data systems is strictly controlled through role-based permissions. Staff members are granted access only to the data necessary to perform their duties. Access rights are reviewed periodically and adjusted where roles change or employment ends.

The school conducts regular internal audits of data systems, access logs, and security procedures to ensure continued compliance. These audits are overseen by senior leadership and reported to governance.

An established Incident Response Procedure is in place to ensure that any suspected or confirmed data breach is handled swiftly, proportionately, and transparently.

---

8. AI & Digital Learning Platforms

As an institution integrating AI-enhanced learning systems, Edenbridge Grammar School ensures that all digital and AI platforms operate within strict data protection and child safeguarding parameters.

AI systems used within the school must comply with child data protection principles and must only process data necessary for educational purposes. Student data used within adaptive or personalised learning systems is limited to supporting curriculum delivery, assessment insight, and learner progression.

Under no circumstances is student data sold, commercially exploited, transferred for marketing purposes, or monetised. The school does not permit behavioural profiling beyond educational needs.

All third-party AI and technology providers must enter into formal contractual agreements that include Data Processing Agreements (DPAs), confidentiality clauses, and security assurances aligned with international best practice.

Automated processing or analytics tools are used solely to support educational insight. Final academic decisions, safeguarding determinations, and professional judgments remain the responsibility of qualified educators and school leadership.

AI serves as a support mechanism to enhance learning visibility and responsiveness; it does not replace human oversight or professional discretion.

---

9. Data Sharing

Edenbridge Grammar School shares personal data only where there is a lawful and legitimate basis for doing so.

Data may be shared when required by law, including compliance with court orders, regulatory authorities, or lawful government requests. Information may also be shared where necessary for safeguarding purposes, particularly where a child's welfare or safety is at risk.

Academic records may be shared with recognised examination boards, accreditation bodies, or education regulators where required for certification or compliance.

In circumstances where sharing is not legally mandated, explicit and informed parental consent will be obtained prior to disclosure.

Where external service providers process data on behalf of the school — including cloud platforms, AI systems, payroll services, or examination systems — formal Data Processing Agreements are mandatory. These agreements ensure that third parties meet equivalent data protection standards and do not use the data for any unauthorised purpose.

The school maintains a record of data sharing arrangements and conducts due diligence on all external providers.

---

10. Data Retention

Edenbridge Grammar School operates under a structured Data Retention Schedule which defines how long specific categories of data are retained.

Student academic records are retained in accordance with educational best practice and regulatory requirements. Safeguarding records are retained for extended periods where required to ensure child protection continuity and legal compliance.

Staff employment records are retained in line with employment law requirements. Financial records are maintained according to accounting and audit regulations applicable within Pakistan.

Once retention periods expire, data is securely destroyed. Digital records are permanently deleted using secure deletion protocols. Paper records are shredded or destroyed through secure disposal services.

Retention timelines are reviewed periodically to ensure alignment with evolving regulatory standards.

---

11. Individual Rights

Parents, students (where age-appropriate), and staff have clearly defined rights regarding their personal data.

Individuals have the right to request access to the personal data held about them. They may request correction of inaccurate or incomplete information. Where legally permissible, individuals may request erasure of their data or restriction of processing. Consent-based processing may be withdrawn at any time.

All requests must be submitted in writing to the Data Protection Officer (DPO). The school will acknowledge receipt of the request within seven (7) working days and respond within a reasonable timeframe, typically not exceeding thirty (30) days, unless the request is complex.

Identity verification may be required before processing any request to ensure data security.

11A. Data Deletion Procedure

Where a valid request for data erasure is received and the school determines that there is no overriding legal, safeguarding, or regulatory reason to retain the data, the following steps will be undertaken:

1. **Request Acknowledgement** – The DPO acknowledges receipt of the request in writing within seven (7) working days.
2. **Verification** – The identity of the requesting party is verified.

3. **Legal Assessment** – A review is conducted to determine whether the data is required for legal, safeguarding, financial, or regulatory obligations.
4. **System Identification** – All systems and storage locations where the data exists are identified.
5. **Secure Deletion** – Data is permanently deleted from active systems, archives (where permissible), and backup structures in accordance with secure deletion standards.
6. **Third-Party Notification** – Where data has been shared with contracted third parties, those processors are formally instructed to delete the relevant data.
7. **Confirmation Notice** – Once deletion is complete, written confirmation is provided to the requesting party, detailing the scope of deletion.

Where deletion cannot occur due to legal obligations (for example, safeguarding or statutory record retention), the school will inform the requesting party of the lawful basis for continued retention.

All deletion actions are logged for audit purposes.

---

12. Data Breach Management

In the event of a suspected or confirmed data breach, immediate action is taken to contain the incident and prevent further exposure.

An internal investigation is initiated to determine the nature, scope, and potential impact of the breach. All incidents are formally documented.

A risk assessment is conducted to evaluate potential harm to affected individuals. Where required by law, relevant authorities — including the FIA Cyber Crime Wing — will be notified in accordance with national regulations.

Where there is significant risk to individuals' rights or safety, affected parties will be informed promptly and provided with guidance on protective measures.

Following resolution, a full review is conducted to implement corrective action, strengthen safeguards, and prevent recurrence.

All breaches are recorded in a central incident register and reviewed periodically by senior leadership and governance.

---

13. Governance and Accountability

Edenbridge Grammar School appoints a designated Data Protection Officer (DPO) responsible for overseeing compliance with this policy and applicable laws.

The DPO monitors data handling practices, advises leadership on regulatory developments, and ensures that risk assessments are conducted where necessary.

This policy is formally reviewed on an annual basis or sooner if legislative changes or significant operational developments occur.

Governors receive periodic reports on data protection compliance, cybersecurity posture, and any breach incidents. Data protection is recognised as a standing governance responsibility.

---

14. Training & Awareness

Data protection is embedded into the professional culture of the school.

All staff receive structured induction training covering confidentiality, lawful processing, safeguarding-linked data handling, and cybersecurity awareness. Annual refresher sessions reinforce expectations and respond to evolving digital risks.

Specialised training is provided for staff involved in handling sensitive safeguarding data or managing AI-supported systems.

Students are taught age-appropriate digital citizenship, including privacy awareness, responsible technology use, and online safety. These principles are integrated into the broader character and digital literacy curriculum.

---

15. Policy Review

This policy will be reviewed:

- Annually

- Following regulatory changes
- Following any major data breach
- Upon significant system changes

Approval

Approved by: _____
Position: _____
Date: _____
Next Review Date: _____